ПР1. Моделирование угроз цифровой образовательной среды

Условная образовательная организация «Школа цифровых практик»

Индивидуальный вариант № 8: олимпиадный сервис

Джамалова Сабина Шахиновна, группа МПИНФ-261м

Цель: научиться выделять наиболее значимые информационные активы ОУ, описывать основные потоки данных, формулировать риски и выбирать меры защиты с учётом влияния на образовательный процесс.

1. Пять критичных активов

Критерий выбора: актив либо содержит персональные данные большого числа обучающихся, либо без него останавливается обучение.

Актив	**Что защищаем**	**Критичное свойство**	**Почему важен**
Локальная база контингента (A7)	ФИО, класс, статус обучения 850 обучающихся; источник состава классов для журнала (F5)	Конфиденциальность (вторично: целостность)	Содержит ПДн всех обучающихся. Самое тяжёлое нарушение: массовая утечка или выгрузка; при потере или порче данных журнал и LMS остаются без состава классов.
Электронный журнал (A2)	Оценки, посещаемость, данные контингента	Целостность	Основа учёта успеваемости. Подмена или потеря оценок ведёт к ошибкам в аттестации и спорам с родителями; XLSX-выгрузки создают копии вне защищённого контура.
LMS (A1)	Учебные материалы, работы и результаты обучающихся, тесты	Доступность (и целостность)	Доступна из Интернета, MFA есть только у администраторов. Недоступность в период тестов и аттестации срывает обучение сильнее любой утечки.

Актив	Что защищаем	Критичное свойство	Почему важен
Видеоконференции (А6)	Аудио, видео, чат; ссылки на онлайн-занятия, консультации, родительские собрания	Конфиденциальность и доступность	Ссылки пересылаются через классные чаты. Нарушение конфиденциальности: посторонний на занятии с детьми; нарушение доступности: срыв дистанционного занятия.
Внешние сервисы олимпиад, кружков и проектов (новый актив А11)	Регистрационные сведения участников (F10), результаты, доступ педагога к сервису	Конфиденциальность	Данные покидают контур школы; единого перечня разрешённых сервисов и токенов нет. После передачи школа не контролирует хранение и не всегда может отозвать доступ.

2. Схема цифровой среды

На схеме показаны педагог, обучающийся, администрация, LMS, электронный журнал, локальная база, файловое облако, NAS и внешний сервис А (олимпиадная платформа, название условное). Использованы две доверительные границы: внутренний контур школы (ГД-1) и внешний сервис (ГД-2). К каркасу из задания добавлены рабочее место педагога с XLSX-выгрузками (F12) и шаг проверки полей по шаблону (F10-A0): именно через них список участников попадает во внешний сервис (подробно в разделе 4).

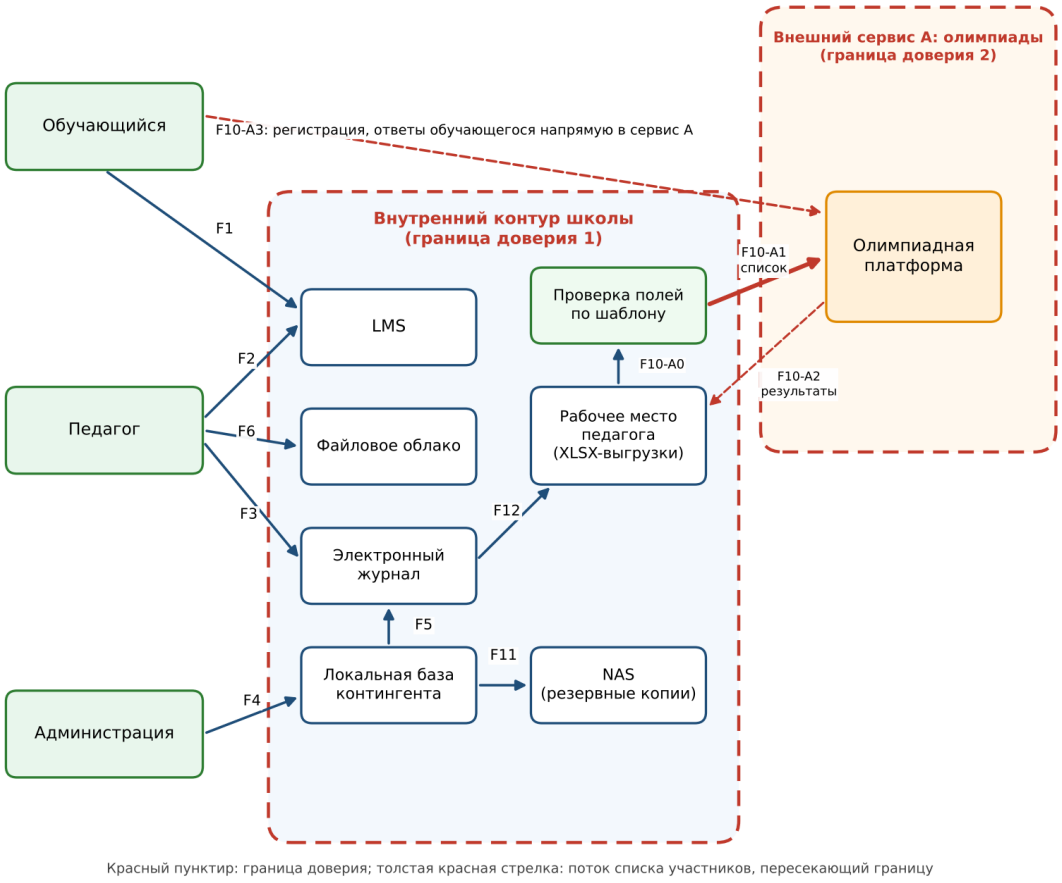


Рисунок 1. Схема потоков данных. Внешний сервис находится вне границы доверия школы, поток списка участников показан отдельно.

Та же схема в Mermaid:

```
flowchart LR
    S["Обучающийся"]
    T["Педагог"]
    AD["Администрация"]
    subgraph SCH["Внутренний контур школы (граница доверия 1)"]
        LMS["LMS"]
        EJ["Электронный журнал"]
        CL["Файловое облако"]
        DB[("Локальная база контингента")]
        NAS[("NAS: резервные копии")]
        WS["Рабочее место педагога<br/>XLSX-выгрузки"]
        CHK["Проверка полей по шаблону"]
    end
    subgraph EA["Внешний сервис A: олимпиады (граница доверия 2)"]
        A["Олимпиадная платформа"]
    end
    S -->|"F1 работы, ответы тестов"| LMS
    T -->|"F2 задания, оценки"| LMS
    T -->|"F3 оценки, посещаемость"| EJ
    T -->|"F6 учебные файлы"| CL
    AD -->|"F4 данные контингента"| DB
    DB -->|"F5 состав классов"| EJ
    DB -->|"F11 резервная копия"| NAS
    EJ -->|"F12 XLSX-выгрузка"| WS
    WS -->|"F10-A0 отбор полей"| CHK
    CHK ==>|"F10-A1 минимальный список участников"| A
    A -->|"F10-A2 результаты"| WS
    S -->|"F10-A3 регистрация, ответы"| A
    classDef ext fill:#fff4e5,stroke:#c0392b,stroke-dasharray:5 3
    class A ext
```

Поток	Откуда -> куда	Данные	Граница
F1	Обучающийся -> LMS	работы, ответы тестов	вход в ГД-1 из Интернета
F2, F3, F6	Педагог -> LMS / журнал / облако	задания, оценки, посещаемость, файлы	вход в ГД-1 (без MFA у педагогов)
F4, F5	Администрация -> база -> журнал	данные контингента, состав классов	внутри ГД-1
F11	База -> NAS	ночная резервная копия	внутри ГД-1
F12	Журнал -> рабочее место педагога	XLSX-выгрузка (локальная копия ПДн)	внутри ГД-1, но вне контроля системы
F10-A0	Рабочее место -> проверка по шаблону	отбор полей: ID, класс	внутри ГД-1
F10-A1	Проверка -> сервис А	список участников (ID, класс)	ГД-1 -> ГД-2
F10-A2 / A3	Сервис А <-> педагог, обучающийся	результаты; регистрация, ответы	ГД-2

3. Реестр пяти рисков

Сценарии записаны как «источник -> уязвимость -> событие -> последствие».

ID	Актив	Сценарий	P	I	R	Меры защиты	Остаточный
R1	Файловое облако (А4)	педагог (без умысла) -> публичные ссылки создаются свободно, старые ссылки не проверяются -> ссылка на файл с работами или списками остаётся открытой и попадает к посторонним -> раскрытие работ и ПДн обучающихся	3	4	12	срок действия и пароль для публичных ссылок; запрет публичных ссылок на файлы с ПДн; ежеквартальный просмотр и отзыв старых ссылок	2 × 3 = 6
R2	Видеоконференции (А6)	посторонний -> ссылка без пароля и зала ожидания пересылается через классные чаты -> посторонний подключается к занятию -> видит и слышит детей, срывает занятие, возможна запись	4	4	16	пароль и зал ожидания; ссылка на каждое занятие отдельно, со сроком действия; раздача ссылок только через LMS; право хоста удалять участников;	2 × 4 = 8

						запрет записи участниками	
R3	Учётная запись педагога (LMS, журнал)	фишинг -> у педагогов нет MFA -> компрометация учётной записи -> доступ к работам и оценкам своих классов, экспорт XLSX, подмена оценок или заданий	3	4	12	MFA для педагогов; уведомление о новом входе; ограничение массового экспорта; короткий инструктаж по фишингу	2 × 4 = 8
R4	Локальная база контингента + NAS (A7, A8)	сбой диска или шифровальщик -> резервная копия не проверялась восстановлением около 8 месяцев -> копия оказалась неполной или несовместимой -> база и журнал недоступны днями, срыв учёта и аттестации	3	5	15	контрольное восстановление раз в квартал на тестовом стенде; вторая копия вне NAS (офлайн); контроль успешности ночного копирования; зафиксированное время восстановления	2 × 3 = 6
R5	Внешние сервисы, учётные записи и токены (A11)	уволившийся или сменивший роль педагог -> единого перечня сервисов и токенов нет, блокировка вручную только в основных системах -> аккаунты и токены во внешних сервисах остаются активными -> несанкционированный доступ к спискам участников и результатам	3	4	12	реестр внешних сервисов и токенов с владельцем и сроком; блокировка по чек-листу в день приказа; смена токенов при уходе владельца; ежеквартальная сверка	2 × 3 = 6

Исходные риски высокие (12-16), остаточные умеренные (6-8). Меры по R1, R4, R5 снижают и вероятность, и тяжесть последствий; по R2 и R3 только вероятность (при входе постороннего или взломе аккаунта ущерб остаётся прежним, MFA и зал ожидания его не уменьшают).

Обоснование риска R2

Почему такие P и I. P = 4: ссылку легко переслать, это уже происходит через классные чаты, встречи регулярны, а пароль и зал ожидания не используются. I =

4: на занятии присутствуют изображение и голоса детей, посторонний их видит и слышит, возможны запись и жалобы родителей. **Почему меры снижают риск.** Пароль и зал ожидания не пускают человека, который получил ссылку не по назначению (P: 4 -> 2); персональная ссылка на занятие со сроком действия и выдача через LMS убирают сам путь распространения. Тяжесть последствий не меняется (I = 4), поэтому риск смещается только по горизонтали. **Чем опасен для образования.** Срывается урок целиком, в дистанционном формате его нельзя «досидеть» иначе, а дети сталкиваются с оскорблениями и вмешательством в чате; педагог теряет время и контроль над группой.

Обоснование риска R4

Почему такие P и I. P = 3: ночная копия есть, но полное восстановление не проверялось около восьми месяцев, поэтому её пригодность неизвестна, а сбой носителя или шифровальщик остаются реалистичным событием. I = 5: от базы контингента зависят состав классов в журнале и доступ к заданиям, её недоступность на несколько дней по шкале означает срыв аттестации. **Почему меры снижают риск.** Квартальное контрольное восстановление превращает «копия вроде бы есть» в известное время восстановления (I: 5 -> 3), а вторая копия вне NAS не даст шифровальщику уничтожить и оригинал, и резерв (P: 3 -> 2). **Чем опасен для образования.** Без списков классов педагоги не могут открыть журнал и выдать задания, учёт приходится вести вручную, а итоги четверти откладываются.

4. Индивидуальный вариант № 8

Задание 1. Риск передачи внешнему сервису избыточных данных (R6)

ID	Актив	Сценарий	P	I	R	Меры защиты	Остаточный
R6	Внешний сервис олимпиад (A11), XLSX-выгрузки	педагог (ошибка, без умысла) -> нет перечня разрешённых сервисов и шаблона полей выгрузки -> в олимпиадную платформу загружен полный XLSX-список класса -> лишние ПДн обучающихся (ФИО, контакты, статус) оказались у внешнего поставщика без гарантии удаления	4	4	16	перечень разрешённых сервисов; карточка согласования; шаблон выгрузки только с ID и классом; проверка файла перед загрузкой; условия удаления данных	2 × 3 = 6

Почему такие P и I. P = 4: выгрузка XLSX из журнала доступна педагогам, шаблона полей и перечня сервисов нет, а олимпиады, кружки и проекты идут в течение каждой четверти, то есть ситуация повторяется регулярно и не требует от педагога ничего, кроме ошибки. I = 4: по шкале это раскрытие ПДн многих обучающихся с вероятными жалобами родителей; вернуть данные от внешнего поставщика школа не может, поэтому ущерб необратим. **Почему меры снижают риск.** Шаблон с ID и классом и проверка файла убирают саму возможность загрузить лишние поля (P: 4 -> 2), а минимальный состав данных снижает тяжесть последствий, даже если файл всё же уйдёт (I: 4 -> 3). Перечень разрешённых сервисов и карточка согласования делают передачу осознанной. **Чем опасен для образования.** Олимпиады и проекты - это часть работы с одарёнными детьми; после жалоб школа может запретить внешние сервисы целиком, и обучающиеся потеряют эти возможности.

Задание 2. Поток загрузки списка участников

Поток показан на рисунке 1 и в Mermaid-коде (F12 -> F10-A0 -> F10-A1) и пересекает границу доверия между школой и олимпиадной платформой. Порядок действий при загрузке:

Шаг	Действие	Поток	Где находятся данные
1	Педагог выгружает из журнала список класса в XLSX	F12	рабочее место педагога (локальная копия)
2	Из файла удаляются все поля, кроме ID и класса (e-mail только если сервис без него не работает)	F10-A0	рабочее место, проверка по шаблону
3	Файл проверяется: нет ФИО-списков целиком, контактов, оценок; число строк равно числу участников	F10-A0	рабочее место, проверка по шаблону
4	Загрузка списка в личный кабинет олимпиадной платформы	F10-A1	переход через границу ГД-1 -> ГД-2
5	После завершения олимпиады педагог удаляет список и аккаунты участников, локальный XLSX удаляется	F10-A2	сервис A и рабочее место

Задание 3. Три критерия выбора допустимого внешнего сервиса

№	Критерий	Что проверяется
1	Минимальный состав данных	сервис работает с ID и классом и не требует ФИО-списков целиком, контактов и профиля LMS; поля регистрации можно сократить

№	Критерий	Что проверяется
2	Возможность отзыва и удаления	в условиях указан срок хранения; список и аккаунты можно удалить самому или по запросу с подтверждением; после мероприятия доступ закрывается
3	Прозрачность поставщика	известны юридическое лицо и место хранения данных, есть политика обработки ПДн, данные не передаются третьим лицам, вход педагога защищён паролем и MFA

Сервис, не прошедший хотя бы один критерий, проходит согласование только с руководством и ответственным за ПДн, а до решения данные ему не передаются.

5. Вывод

Наиболее значимый риск: R6 (избыточная передача данных обучающихся во внешний сервис, R = 16 -> 6). Он высокий по обеим шкалам: возникает от обычной ошибки педагога, и последствие необратимо, потому что после загрузки школа не контролирует данные у поставщика. Он влияет именно на образовательный процесс, так как внешние олимпиады, кружки и проекты являются частью работы с обучающимися: при инциденте школе придётся ограничить такие сервисы, а обучающиеся потеряют возможности участия.

Первая мера: до любой новой загрузки данных во внешний сервис ввести перечень разрешённых сервисов и обязательную карточку согласования, а выгрузки делать только по шаблону с минимальными полями (ID и класс) с проверкой файла перед загрузкой. Вторым шагом, без затрат, включить пароль и зал ожидания для всех видеовстреч и перестать рассылать ссылки в классных чатах (R2).